

Rapport de conformité — Label EBIOS Risk Manager (ANSSI)

Application évaluée : ACRA — Augmented Cyber Risk Analysis

Référentiels de comparaison :

- *Cahier des charges — Labellisation des solutions logicielles EBIOS Risk Manager, v3.1 du 01/10/2024* (ANSSI)
- *Guide EBIOS Risk Manager, v1.5 de septembre 2024* (ANSSI / Club EBIOS) — conforme ISO/IEC 27005:2022
- *Procédure d'obtention du label EBIOS Risk Manager* (ANSSI)

Date de l'évaluation : 5 juillet 2026

Nature du document : auto-évaluation interne. **ACRA ne sollicite pas la labellisation** ; ce rapport sert au pilotage de l'alignement méthodologique et à l'identification des écarts. Il ne préjuge pas de l'appréciation de l'ANSSI.

■ **Portée du label (rappel EXI_S6_02 à S6_04).** L'évaluation ANSSI se restreint aux **aspects fonctionnels** de la solution vis-à-vis de la méthode. Le label ne se substitue pas à une certification/qualification (visa de sécurité) et ne garantit pas la robustesse de l'application face à des actions malveillantes.

1. Synthèse générale

ACRA instancie **les 5 ateliers de la méthode EBIOS RM de bout en bout**, avec une fidélité méthodologique forte sur les concepts structurants : critères **DICT**, **couples source de risque / objectif visé (SR/OV)**, **cartographie de dangerosité de l'écosystème** (formule et zones conformes au guide), **scénarios stratégiques et opérationnels**, **cartographies de risque initial et résiduel**. La terminologie est **alignée sur EBIOS RM v1.5** (« traitement du risque », « plan de traitement » ; pas d'emploi du terme obsolète « PACS »).

Verdict global : conformité **méthodologique élevée** sur le cœur de la méthode ; **écarts fonctionnels ciblés** sur des exigences précises du cahier des charges (mention de protection, gestion des versions x.y, cartographie radar SR/OV, opérateurs ET/OU, trois méthodes de vraisemblance, catégorisation EBIOS des mesures).

Atelier / Chapitre	Exigences	Couverture	Verdict
§3 Spécifications générales	4 thèmes	Partielle	● Partiel
Atelier 1 — Cadrage & socle	EXI_M1_01→23	Élevée	● Conforme
Atelier 2 — Sources de risque	EXI_M2_01→10	Élevée (hors radar)	● Partiel
Atelier 3 — Scénarios stratégiques	EXI_M3_01→28	Très élevée	● Conforme
Atelier 4 — Scénarios opérationnels	EXI_M4_01→18	Partielle	● Partiel
Atelier 5 — Traitement du risque	EXI_M5_01→12	Élevée	● Conforme
§5 Exigences de sécurité	EXI_S1→S6	Élevée (mode client-serveur)	● Conforme
§6 Exigences SaaS	EXI_SNC1→4	Non applicable (auto-hébergé)	N/A

Légende : ● **Conforme** conforme / largement couvert · ● **Partiel** partiel · ● **Écart** écart · N/A non applicable.

2. Partie A — Conformité méthodologique (EBIOS RM 2024 / v1.5)

Vérification de l'alignement des concepts et de la terminologie du guide v1.5.

Concept EBIOS RM v1.5	Implémentation ACRA	Statut
5 ateliers (Cadrage, Sources de risque, Scénarios stratégiques, Scénarios opérationnels, Traitement)	ATELIERS_META + Atelier1..5.tsx	● Conforme
Critères de sécurité DICT (Disponibilité, Intégrité, Confidentialité, Traçabilité)	CRITERES_DICT	● Conforme
Valeurs métier (processus / information) + propriétaire	VALEURS_METIER_EXEMPLES, champ responsable	● Conforme
Biens supports rattachés aux valeurs métier	BIENS_SUPPORTS_EXEMPLES, TYPES_BIEN_SUPPORT	● Conforme
Événements redoutés + échelle de gravité	EVENEMENTS_REDOUTES_EXEMPLES, NIVEAUX_GRAVITE	● Conforme
Socle de sécurité par conformité (référentiels + écarts)	Étape 5 A1, referentiels/referentielMesures	● Conforme
Typologie des sources de risque	SOURCES_RISQUE_EXEMPLES (cybercriminel, étatique, concurrent, terroriste, activiste, amateur, interne malveillant, prestataire)	● Conforme
Couples SR/OV comme unité d'analyse + pertinence	Atelier2.tsx (motivation/ressources/activité → pertinence)	● Conforme
Cartographie de dangerosité de l'écosystème : exposition = dépendance × pénétration ; fiabilité = maturité × confiance ; menace = expo/fiab	ecosystem-radar.ts, EcosystemRadar.tsx	● Conforme
Zones danger / contrôle / veille	zoneOf, seuils de zone	● Conforme
Scénarios stratégiques = chemins d'attaque via parties prenantes	Atelier3.tsx, ScenarioStrategique	● Conforme
Scénarios opérationnels = séquence d'actions élémentaires	Atelier4.tsx, TYPES_ACTION_ELEMENTAIRE (reconnaissance → impact)	● Conforme
Vraisemblance (1–4) ; risque = gravité × vraisemblance	NIVEAUX_VRAISEMBLANCE, niveauRisque	● Conforme
Stratégies de traitement (réduire / accepter / transférer / refuser)	STRATEGIES_TRAITEMENT	● Conforme
Risque résiduel après mesures	graviteResiduelle, vraisemblanceResiduelle	● Conforme
Terminologie v1.5 : « traitement du risque », « plan de traitement » (et non « PACS »)	Atelier 5 « Traitement du risque » ; libellés « plan d'action / plan de traitement »	● Conforme

Conclusion Partie A (répond aux points de veille #55 et #99). Aucun écart terminologique ou conceptuel critique avec EBIOS RM 2024 / v1.5. Le vocabulaire, les échelles, la typologie des sources de risque et les types d'actions élémentaires sont cohérents avec le guide. Réserve mineure : ACRA emploie « plan d'action » comme synonyme d'usage de « plan de traitement du risque » — à uniformiser sur le terme officiel dans l'UI et les exports (cf. écart G-06).

3. Partie B — Matrice de conformité au cahier des charges v3.1

3.1 Spécifications générales (§3)

Réf.	Exigence (résumé)	Statut	Constat
§3.1	Dérouler les 5 ateliers de bout en bout, mode agile, export par étape	● Partiel	Ateliers complets et navigation libre ; export de livrables par atelier/étape non individualisé (export PDF global)
§3.2	Mention de protection obligatoire (non protégée / sensible / restreinte / confidentielle)	● Conforme	Corrigé (G-01) : champ Analyse.mentionProtection + lib/mention-protection.ts ; sélecteur à la création, badge en application, marquage sur la page de garde et le pied de page des exports

Réf.	Exigence (résumé)	Statut	Constat
§3.3	Guide d'utilisation (installation, fonctions de base, recommandations)	● Partiel	README + panneaux de guidage in-app ; pas de guide utilisateur dédié complet
§3.4	Gestion des versions x.y des analyses (cycle op./strat., incrément, synthèse des MàJ)	● Écart	Pas de versionnage x.y par analyse ni synthèse des révisions

3.2 Atelier 1 — Cadrage et socle de sécurité (EXI_M1_01→23)

Réf.	Statut	Constat
EXI_M1_01	● Partiel	Objectifs, missions, périmètre présents ; participants (RACI), contraintes, hypothèses, planning non structurés
EXI_M1_02 / 03	● Conforme / ● Partiel	CRUD du cadre OK ; export dédié du cadre via PDF global
EXI_M1_04	● Conforme	Missions de l'objet étudié
EXI_M1_05	● Conforme	Valeurs métier + nature + propriétaire
EXI_M1_06	● Conforme	Biens supports + propriétaire
EXI_M1_07	● Conforme	CRUD périmètre
EXI_M1_08	● Partiel	Export OK ; import du périmètre partiel
EXI_M1_09 / 10	● Conforme	ER : CRUD + association à une/plusieurs valeurs métier
EXI_M1_11	● Partiel	Échelle de gravité présente ; création/édition de plusieurs échelles non offerte (échelle figée en code)
EXI_M1_12	● Conforme	Impacts multiples et configurables (missions, humain, gouvernance, financier...)
EXI_M1_13 / 14	● Conforme	Gravité par couple VM/ER + justifications (champ description)
EXI_M1_15	● Partiel	ER non lié à une valeur métier (risque non intentionnel) non explicitement supporté
EXI_M1_16	● Partiel	Export ER via PDF global
EXI_M1_17 →23	● Conforme	Socle : référentiels + sélection d'exigences + écarts/dérogations + export. Réserve : indicateur d'état vert/orange/rouge à formaliser (EXI_M1_20)

3.3 Atelier 2 — Sources de risque (EXI_M2_01→10)

Réf.	Statut	Constat
EXI_M2_01	● Conforme	Catégories de SR/OV par défaut
EXI_M2_02	● Partiel	Ajout de sources possible ; renommage/gestion des catégories limité
EXI_M2_03	● Conforme	Saisie des objectifs visés par source
EXI_M2_04	● Conforme	Critères motivation / ressources / activité
EXI_M2_05	● Conforme	Métrique de pertinence (calcul automatique + saisie)
EXI_M2_06	● Partiel	Traçabilité des justifications de pertinence partielle
EXI_M2_07	● Partiel	Export des couples via PDF global
EXI_M2_08	● Conforme	Sélection des couples prioritaires (P1 / P2)
EXI_M2_09	● Écart	Cartographie visuelle de type radar des couples SR/OV absente
EXI_M2_10	● Partiel	Rapprochement ER ↔ couples SR/OV partiel (synthèse de liaison)

3.4 Atelier 3 — Scénarios stratégiques (EXI_M3_01→28) — point fort

Réf.	Statut	Constat
EXI_M3_01→04	● Conforme	Catégories de parties prenantes (internes/externes) + recensement caractérisé
EXI_M3_05→07	● Conforme	Dangerosité initiale + 4 critères dépendance / pénétration / maturité / confiance
EXI_M3_08	● Conforme	Édition des métriques de cotation via EchellesEcosystemeEditor (admin)
EXI_M3_09	● Conforme	Formule (Dépendance × Pénétration) / (Maturité × Confiance)
EXI_M3_10 / 11	● Conforme	Traçabilité des cotations + valeur « forçable »
EXI_M3_12 / 13	● Conforme	Seuils des zones + cartographie radar de dangerosité initiale
EXI_M3_14 / 15	● Conforme	Parties prenantes critiques distinguées + édition
EXI_M3_16	● Conforme	Pertinence du couple SR/OV proposée si A4 non réalisé
EXI_M3_17	● Partiel	Export de la cartographie via PDF global
EXI_M3_18→23	● Conforme	Scénarios stratégiques + chemins d'attaque + gravité (issue des ER)
EXI_M3_24→28	● Conforme	Mesures d'écosystème + dangerosité résiduelle + cartographie résiduelle

3.5 Atelier 4 — Scénarios opérationnels (EXI_M4_01→18)

Réf.	Statut	Constat
EXI_M4_01	● Conforme	Scénarios opérationnels liés aux scénarios stratégiques
EXI_M4_03	● Conforme	Liste d'actions élémentaires par défaut, organisées en phases (TYPES_ACTION_ELEMENTAIRE)
EXI_M4_05	● Conforme	Chaque action élémentaire associée à un bien support
EXI_M4_06	● Écart	Opérateurs ET / OU dans les modes opératoires absents
EXI_M4_07	● Écart	Trois méthodes de vraisemblance (expresse / standard / avancée) non offertes explicitement
EXI_M4_09→14	● Partiel	Vraisemblance globale + cotation par action ; algorithme d'agrégation des actions élémentaires vers la vraisemblance globale non implémenté (saisie manuelle)
EXI_M4_16	● Conforme	Vraisemblance globale « forçable »
EXI_M4_17	● Partiel	Identification des actions élémentaires les plus critiques partielle
EXI_M4_18	● Partiel	Export des scénarios via PDF global

3.6 Atelier 5 — Traitement du risque (EXI_M5_01→12)

Réf.	Statut	Constat
EXI_M5_01	● Conforme	Cartographie du risque initial (gravité × vraisemblance)
EXI_M5_02	● Partiel	Export de la cartographie via PDF global
EXI_M5_03	● Écart*	Matrice de traçabilité ER ↔ scénarios de risque absente (<i>exigence optionnelle</i>)
EXI_M5_04	● Conforme	Indicateur de stratégie de traitement (réduire/accepter/transférer/refuser) ; libellés « acceptable / tolérable / inacceptable » à aligner
EXI_M5_05	● Conforme	Mesures associées aux scénarios (objet de l'étude et écosystème)

Réf.	Statut	Constat
EXI_M5_06	● Partiel	Responsable / coût / échéance / avancement OK ; catégorie EBIOS (gouvernance / protection / défense / résilience) non utilisée (ACRA catégorise par référentiel/type ISO)
EXI_M5_07	● Conforme	Plan de traitement du risque + export (« plan d'action »)
EXI_M5_08 →12	● Conforme	Gravité/vraisemblance résiduelles, cartographie résiduelle, documentation des risques résiduels

3.7 Exigences de sécurité (§5 — mode client-serveur)

Réf.	Statut	Constat
EXI_S1_01 →08	● Conforme	Compte d'administration dédié, profils nominatifs, RBAC paramétrable, authentification (mot de passe + MFA), verrouillage de compte, confidentialité des secrets
EXI_S2_01 →03	● Partiel	Confidentialité/intégrité en transit (HTTPS/TLS selon déploiement) ; chiffrement au repos à documenter
EXI_S3_01 →05	● Conforme	Journalisation et imputabilité (journal d'audit : auth, gestion de comptes, accès analyses, événements applicatifs)
EXI_S4_01 →04	● Partiel	Politiques internes de développement (cloisonnement, revue de code, veille tiers) — à formaliser en document éditeur
EXI_S5_01 →06	● Partiel	Maintien en conditions de sécurité, notification CERT-FR — engagements éditeur à formaliser
EXI_S6_01 →06	● Partiel	Disclaimer conditions d'emploi + matrice d'homologation (guides ANSSI) à produire

3.8 Exigences SaaS (§6) — N/A non applicable

Applicables uniquement pour une distribution SaaS labellisée (hébergement SecNumCloud, administration sécurisée, segmentation client, chiffrement des éléments hébergés). ACRA cible un déploiement auto-hébergé (Docker) : non concerné en l'état.

4. Écarts prioritaires et feuille de route

Écarts fonctionnels bloquants ou structurants pour une éventuelle labellisation, par ordre de valeur/effort.

#	Écart	Exigence	Effort	Priorité
~~G-01~~	~~Mention de protection de l'analyse~~ — OK FAIT (commit df0de37)	§3.2	Faible	OK
G-02	Gestion des versions x.y des analyses (cycle op./strat., incrément, synthèse des révisions)	§3.4	Moyen	● Haute
G-03	Cartographie radar des couples SR/OV (Atelier 2)	EXI_M2_09	Moyen	● Partiel Moyenne
G-04	Opérateurs ET/OU dans les modes opératoires (Atelier 4)	EXI_M4_06	Moyen	● Partiel Moyenne
G-05	Trois méthodes de vraisemblance + agrégation des actions élémentaires	EXI_M4_07/09-14	Élevé	● Partiel Moyenne
G-06	Catégorisation EBIOS des mesures (gouvernance/protection/défense/résilience) + uniformiser « plan de traitement du risque »	EXI_M5_06 / v1.5	Faible	● Partiel Moyenne
G-07	Indicateur d'état du socle vert/orange/rouge (appliqué / avec restrictions / non appliqué)	EXI_M1_20	Faible	● Conforme Basse
G-08	Export de livrables par atelier (au-delà du PDF global)	§3.1	Moyen	● Conforme Basse

#	Écart	Exigence	Effort	Priorité
G-09	Cadre de l'étude complet : participants (RACI), contraintes, hypothèses, planning	EXI_M1_01	Faible	● Conforme Basse
G-10	Événement redouté non lié à une valeur métier (risque non intentionnel)	EXI_M1_15	Faible	● Conforme Basse
G-11	Matrice de traçabilité ER ↔ scénarios de risque (optionnel)	EXI_M5_03	Faible	● Conforme Basse
G-12	Matrice d'homologation + disclaimer conditions d'emploi + guide utilisateur dédié	§3.3 / EXI_S6	Faible	● Conforme Basse

Estimation : en traitant G-01, G-02, G-03, G-04, G-06 et G-07, ACRA couvrirait la quasi-totalité des exigences fonctionnelles obligatoires du cahier des charges (les exigences §5/§6 relèvent d'engagements éditeur et de documentation, non de code applicatif pour le mode standalone).

5. Réserves et mentions

- Ce rapport est une **auto-évaluation** ; seule l'ANSSI est habilitée à statuer sur la conformité au label (contact : ebios@ssi.gouv.fr).
- L'évaluation officielle exige la mise en œuvre de l'**exemple fil conducteur du guide** (société fictive de biotechnologie fabriquant des vaccins) afin de contrôler chaque point de la méthode.
- Le label **ne couvre que le fonctionnel** et ne vaut ni certification ni qualification (visa de sécurité), ni garantie de robustesse (EXI_S6_02→04).
- **ACRA n'engage pas de démarche de labellisation** à ce stade ; ce document sert de référentiel d'alignement méthodologique interne.

Sources : cahier des charges du label EBIOS Risk Manager v3.1 (01/10/2024), guide EBIOS Risk Manager v1.5 (09/2024), page « Label EBIOS Risk Manager » — cyber.gouv.fr.